

Chương 9. Triển khai phòng chống DDoS dựa trên Blockchain

Mục tiêu bài học

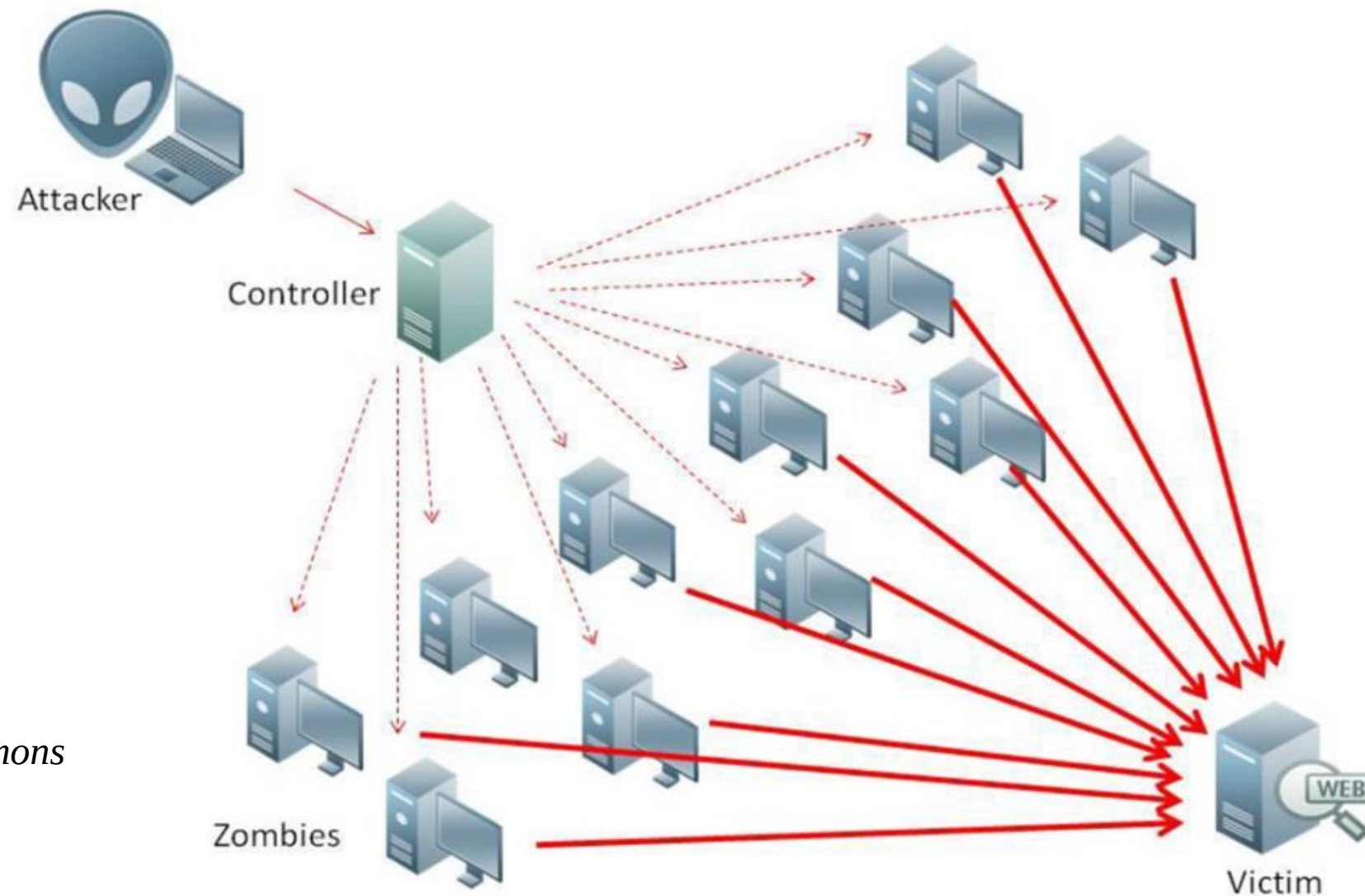
- Hiểu được các cuộc tấn công DDoS.
- Cách áp dụng Blockchain để bảo vệ các tổ chức hiệu quả hơn trước các hoạt động tấn công DDoS lớn.

Nội dung bài học

- Tổng quan về tấn công DDoS.
- Các loại tấn công DDoS.
- Những thách thức với các giải pháp phòng chống DDoS hiện nay.
- Giải pháp Blockchain để chuyển đổi các nền tảng bảo vệ DDoS hiện có.

1. Tổng quan về tấn công DDoS

1.1. Tổng quan



Nguồn: Nasanbuyn / Wiki Commons

1.2. Các giai đoạn của một cuộc tấn công mạng

- **Do thám:** tin tặc xác định mục tiêu và bắt đầu tìm kiếm các lỗ hổng trong đó.
- **Vũ khí hóa:** Kẻ tấn công sử dụng bộ công cụ từ xa và phần mềm độc hại như virus hoặc worm để xâm nhập lỗ hổng bảo mật
- **Phát tán:** Tin tặc cài mã độc vào mạng của nạn nhân thông qua một số phương pháp như email lừa đảo, tải tập tin về ổ đĩa, USB, nội gián...
- **Khai thác:** Mã độc được sử dụng để kích hoạt các cuộc tấn công, thực hiện hành động trên mạng mục tiêu để khai thác lỗ hổng.
- **Cài đặt:** phần mềm độc hại hiện được cài đặt trong máy nạn nhân.
- **Lệnh và điều khiển:** tin tặc truy cập từ xa vào máy nạn nhân bằng các phần mềm độc hại.

a. Xây dựng botnet

- Bản chất phân tán của DDoS đòi hỏi sự tham gia của hàng triệu máy bị nhiễm mã độc trên toàn cầu.
- Tin tặc có thể thuê botnet từ thị trường web đen hoặc tự xây dựng chúng.

Botnet life cycle			
Phases		Instances	Resilience techniques
Injection & Spreading		-Distribution of malicious emails -Software vulnerabilities -Instant Messaging -P2P File sharing Network -Other Botnets	-Using trusted process -Trivial name-based obfuscation -Rootkit Techniques -Reduce Security rules -Reduce system capability -Installing antivirus software -Incorporated antidebugging & antivirtualization -Variant Spreading Techniques -Polymorphism & Metamorphism -Continuous bot upgrade
Command & Control	Model & Topology	-Centralized »Single Star »Multiserver Star »Hierarchical -Distributed »Random	-DNS techniques -Multiple URLs -Encryption Techniques -Dead drop -Variant C&C
	Application & Protocol	-IRC -HTTP -IM -P2P	
	Communication initiation	-Push Method -Pull Method	
	Communication direction	-Inbound -Bidirectional	
Botnet application		-DDoS attacks -Spamming & Spreading malwares -Espionage -Hosting malicious applications & activities	-Exposure limitation -Retaliation techniques -Camouflaged messages - Anonymization techniques

b. Do thám

- Hệ thống mục tiêu mà tin tặc nhắm đến có thể là một trung tâm dữ liệu hoặc chỉ là một máy tính cá nhân.
- Tin tặc tìm kiếm thông tin trực tiếp hoặc gián tiếp liên quan đến mục tiêu của các tổ chức để truy cập trái phép vào tài sản của họ bằng cách vượt qua các hệ thống bảo mật hiện có, như tường lửa, hệ thống ngăn chặn xâm nhập (IPS), tường lửa ứng dụng web và bảo vệ thiết bị đầu cuối.

c. Vũ khí hóa

Một số công cụ phổ biến để phát triển DDoS:

- Low Orbit Ion Cannon (LOIC)
- High Orbit Ion Cannon (HOIC)
- hping
- Slowloris

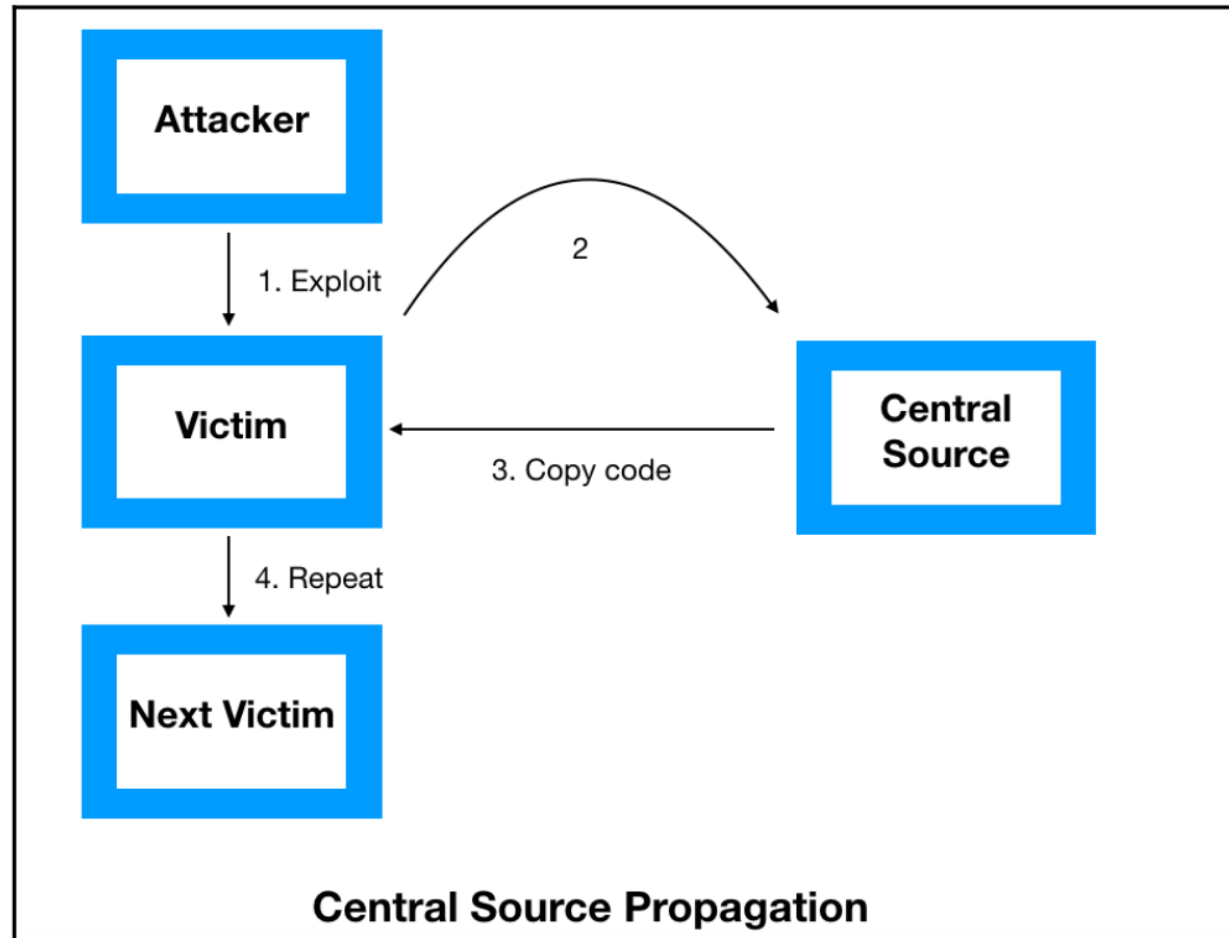
d. Phát tán

Phần mềm chứa mã độc có thể được phát tán qua email lừa đảo hoặc cũng có thể được gửi qua các chiến dịch thư rác. Có 3 nhóm phương pháp để tin tặc phát tán mã độc:

- **Phát tán từ kho lưu trữ trung tâm:**

- Tin tặc tấn công vào hệ thống dễ bị tổn thương, biến nó thành bot, kết nối bot này với kho lưu trữ trung tâm của tin tặc để nhận mã và trở thành bản sao của hệ thống tấn công.
- Cơ sở hạ tầng được lưu trữ tập trung của tin tặc được chuyển sang hệ thống mới bị xâm nhập. Sau đó, một kịch bản sẽ tự động bắt đầu một chu kỳ tấn công mới.
- Toàn bộ cơ chế này sử dụng giao thức HTTP, FTP và RPC.
- Tin tặc khai thác máy nạn nhân, hệ thống bị xâm nhập được kết nối với một kho lưu trữ trung tâm của những kẻ tấn công, và cuối cùng là nguồn trung tâm chuyển mã đến máy nạn nhân.

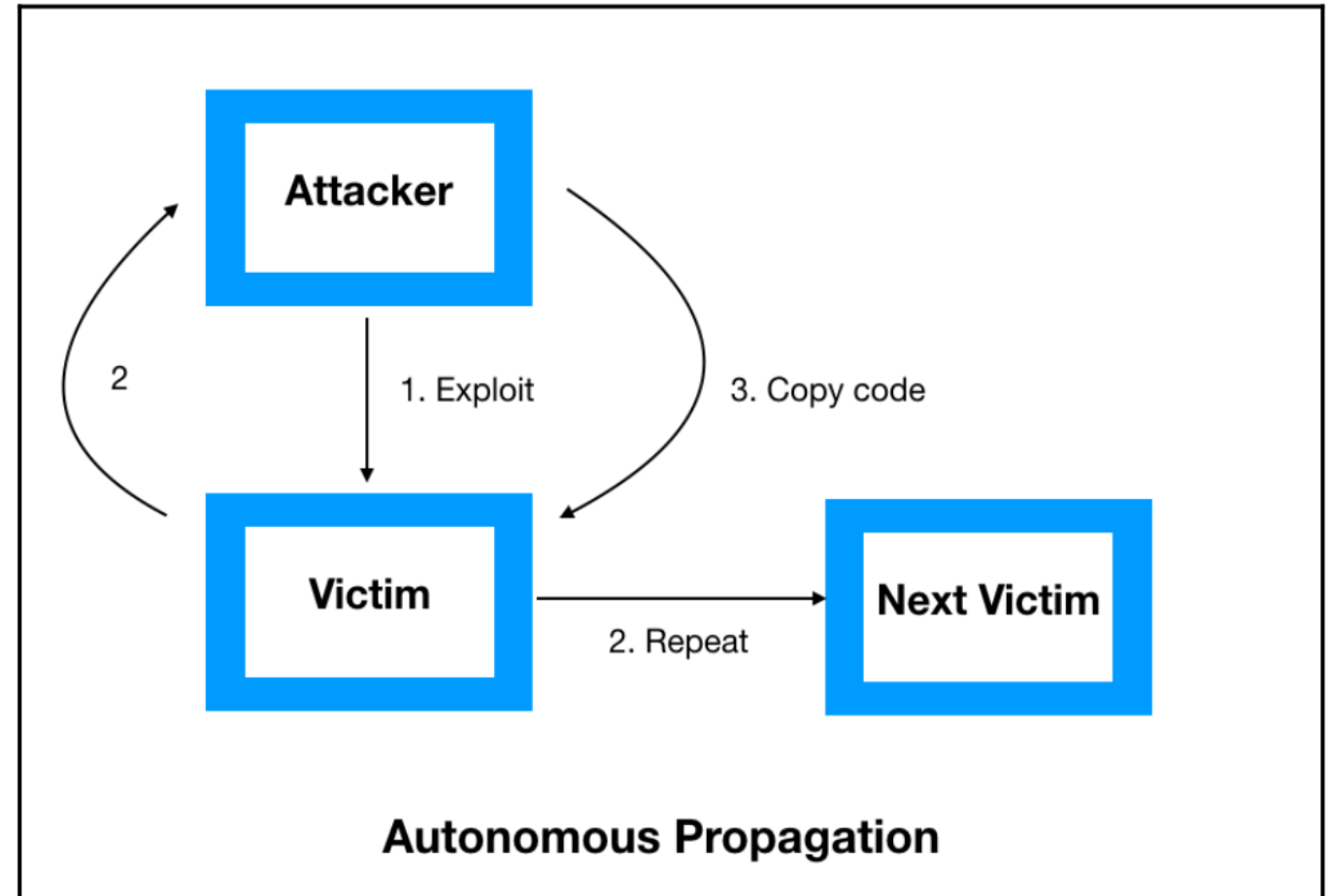
d. Phát tán



d. Phát tán

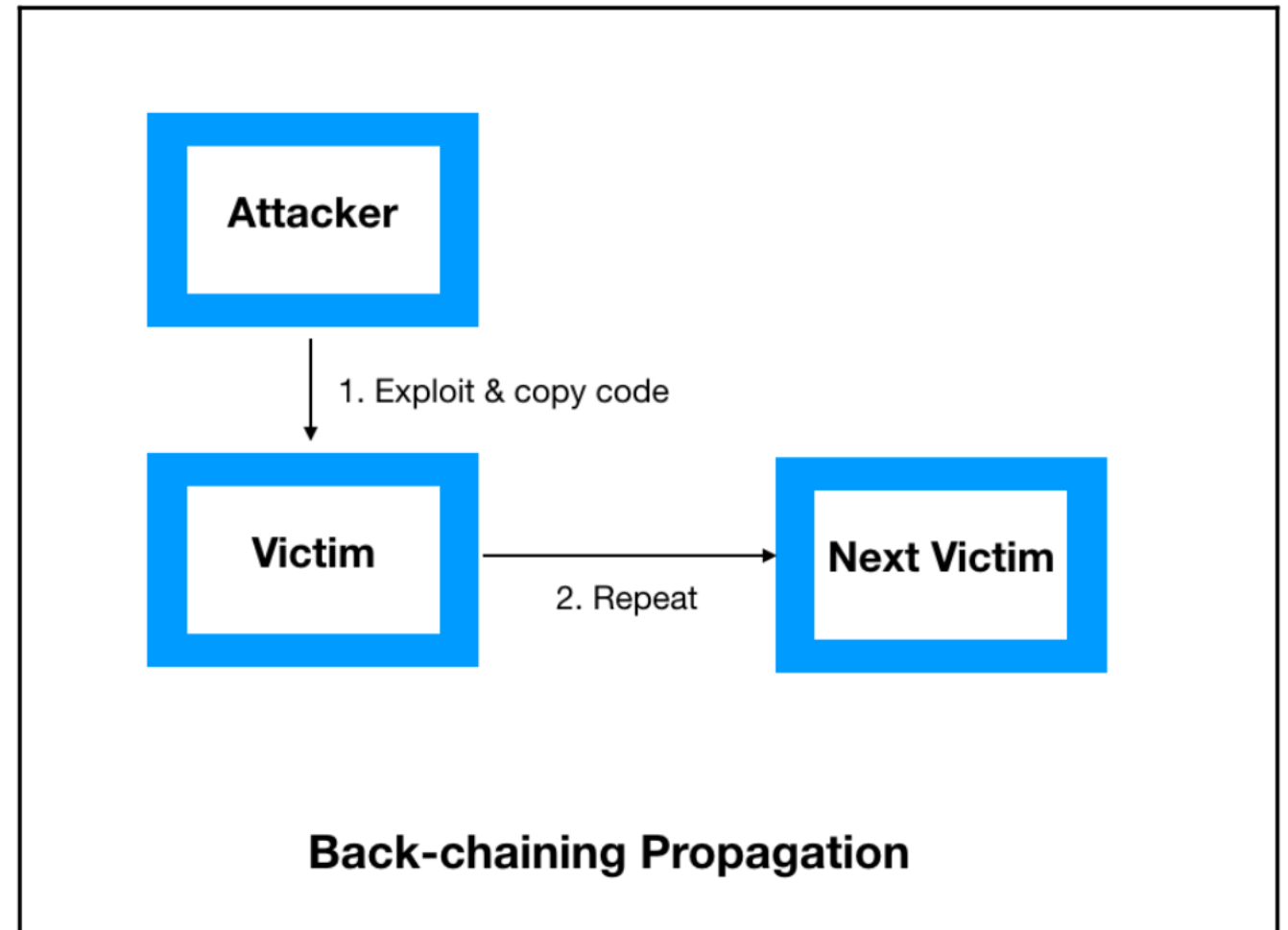
- **Phát tán tự trị:**

- Sau khi đột nhập vào một hệ thống, tin tặc phát tán trực tiếp bộ công cụ tấn công vào máy chủ bị xâm nhập.
- Trước tiên kẻ tấn công truyền mã khai thác, sau đó truyền mã từ chính máy tính của tin tặc mà không phải từ kho lưu trữ trung tâm.



d. Phát tán

- **Phát tán chuỗi ngược:**
 - Bộ công cụ của kẻ tấn công được chuyển đến máy chủ vừa bị xâm nhập.
 - Bộ công cụ này được thiết kế đặc biệt để chấp nhận yêu cầu tập tin từ hệ thống bị xâm nhập.
 - Tin tặc có thể sử dụng TFTP và mở cổng để sao chép tập tin từ máy tính nạn nhân..



e. Khai thác

- Khi phần mềm độc hại được gửi đến mạng, nó sẽ bắt đầu quá trình khai thác các lỗ hổng phần mềm chưa được vá lỗi, các chương trình thực thi mã hóa phần mềm yếu và sự thiếu sự quan tâm của người dùng.
- Với những công cụ khai thác sẵn có và đa dạng như hiện nay, các lỗ hổng sẽ trở thành mồi ngon cho tin tặc khai thác.

f. Cài đặt

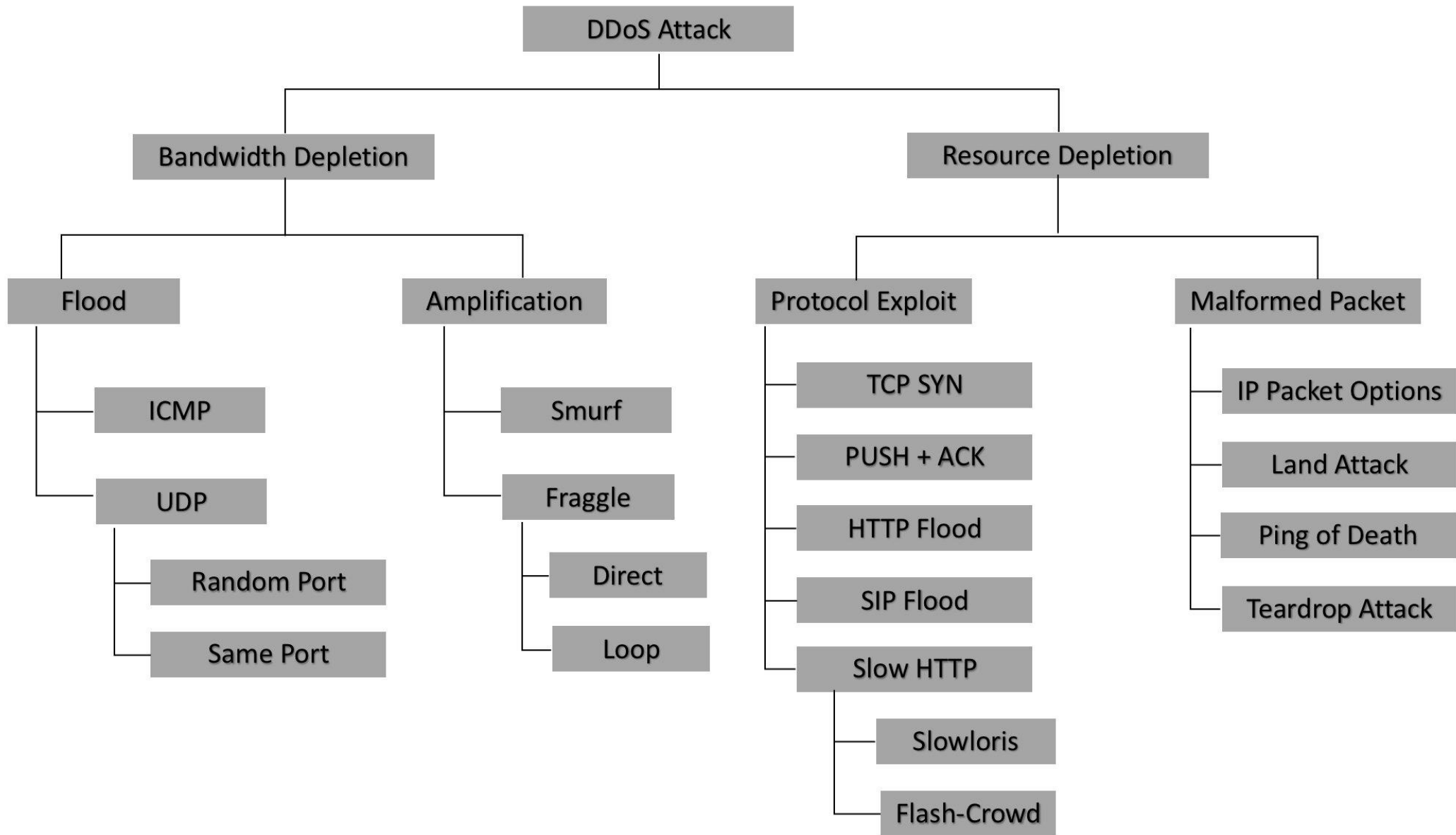
- Trong giai đoạn cài đặt, phần mềm độc hại được cài đặt trong hệ thống mục tiêu và cho phép kẻ tấn công truy cập từ xa.
- Phần mềm độc hại có thể được cài đặt trong các chương trình người dùng hoặc chương trình lỗi của hệ thống.
- Phần mềm độc hại được cài đặt trong chương trình người dùng có khả năng bị phát hiện cao; tuy nhiên, phần mềm độc hại được cài đặt trong chương trình hệ thống ít bị phát hiện bởi các hệ thống bảo mật.

g. Chỉ huy và điều khiển (C2)

- Sau khi mã độc đã được cài đặt thành công, mục tiêu hoàn toàn nằm dưới sự kiểm soát của một hệ thống trung tâm từ xa.
- Botnet vẫn im lặng cho đến khi nó được kích hoạt bởi kẻ tấn công. Thậm chí còn có một số loại giao tiếp bot-to-bot được mã hóa tồn tại trên các mạng ngang hàng công cộng.
- Một khi kênh C2 đã được thiết lập, kẻ tấn công có thể khởi động cuộc tấn công DDoS nhắm vào mục tiêu.
- Ở giai đoạn này, kẻ tấn công thực thi kịch bản để kích hoạt tất cả các chương trình trong toàn bộ botnet.

2. Các loại tấn công DDoS

- Các cuộc tấn công DDoS được thực hiện theo nhiều cách, dựa trên các yếu tố như độ khó của mục tiêu, khả năng tài chính, vấn đề ẩn danh, độ ưu tiên và các yếu tố khác.
- Tin tặc có thể thực thi chương trình tấn công DDoS và khởi động nó mà không cần yêu cầu nhiều chuyên môn kỹ thuật.
- Có ba loại tấn công chủ yếu như sau:
 - Các cuộc tấn công nhắm mục tiêu tài nguyên mạng
 - Các cuộc tấn công nhắm mục tiêu tài nguyên máy chủ
 - Các cuộc tấn công nhắm mục tiêu tài nguyên ứng dụng



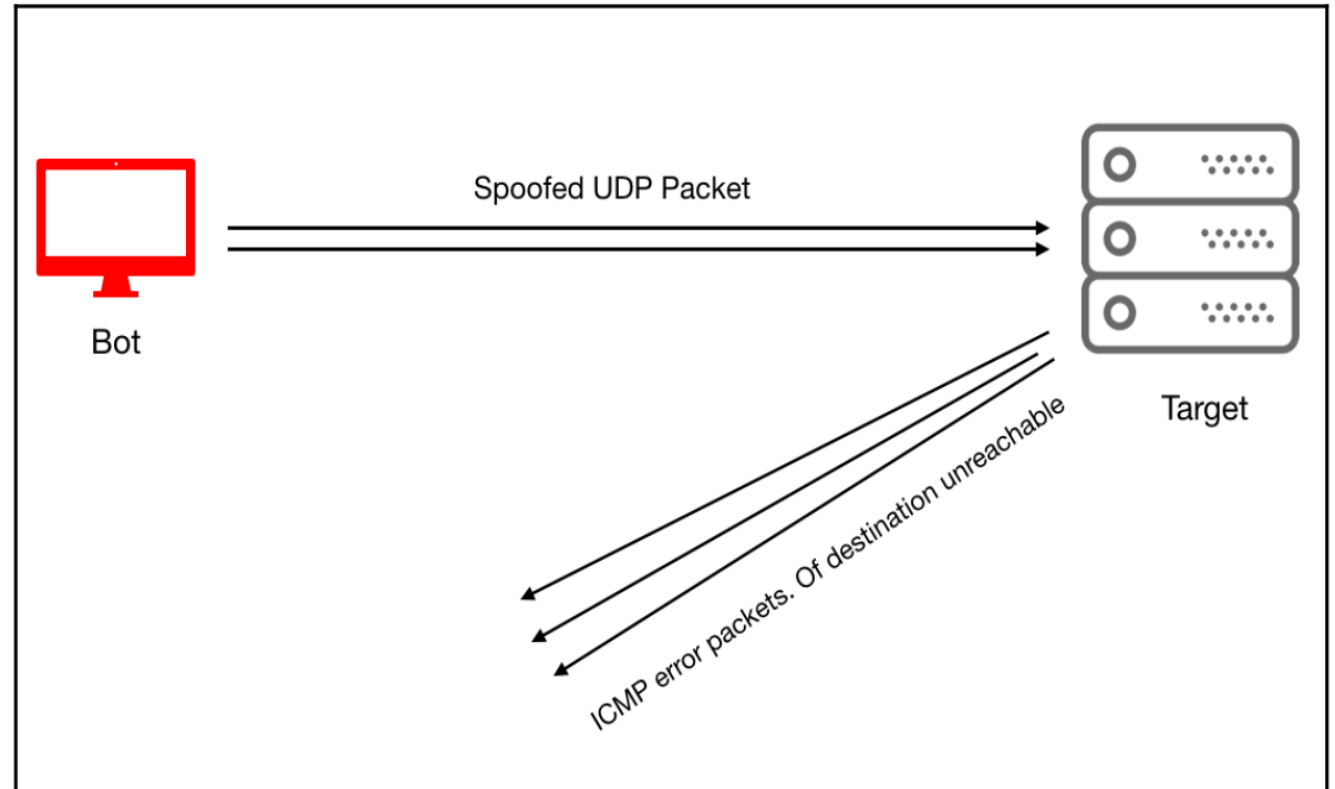
Nguồn: deepai

2.1. Các cuộc tấn công tài nguyên mạng

- Đây là những chiến dịch tấn công được lên kế hoạch để tiêu tốn tài nguyên mạng của hệ thống mục tiêu.
- Trong cuộc tấn công này, băng thông mạng bị cạn kiệt hoàn toàn bởi cuộc tấn công dòng lũ dữ liệu (Flood).
- Một số loại tấn công Flood: UDP Flood, ICMP Flood, IGMP Flood, tấn công khuếch đại...

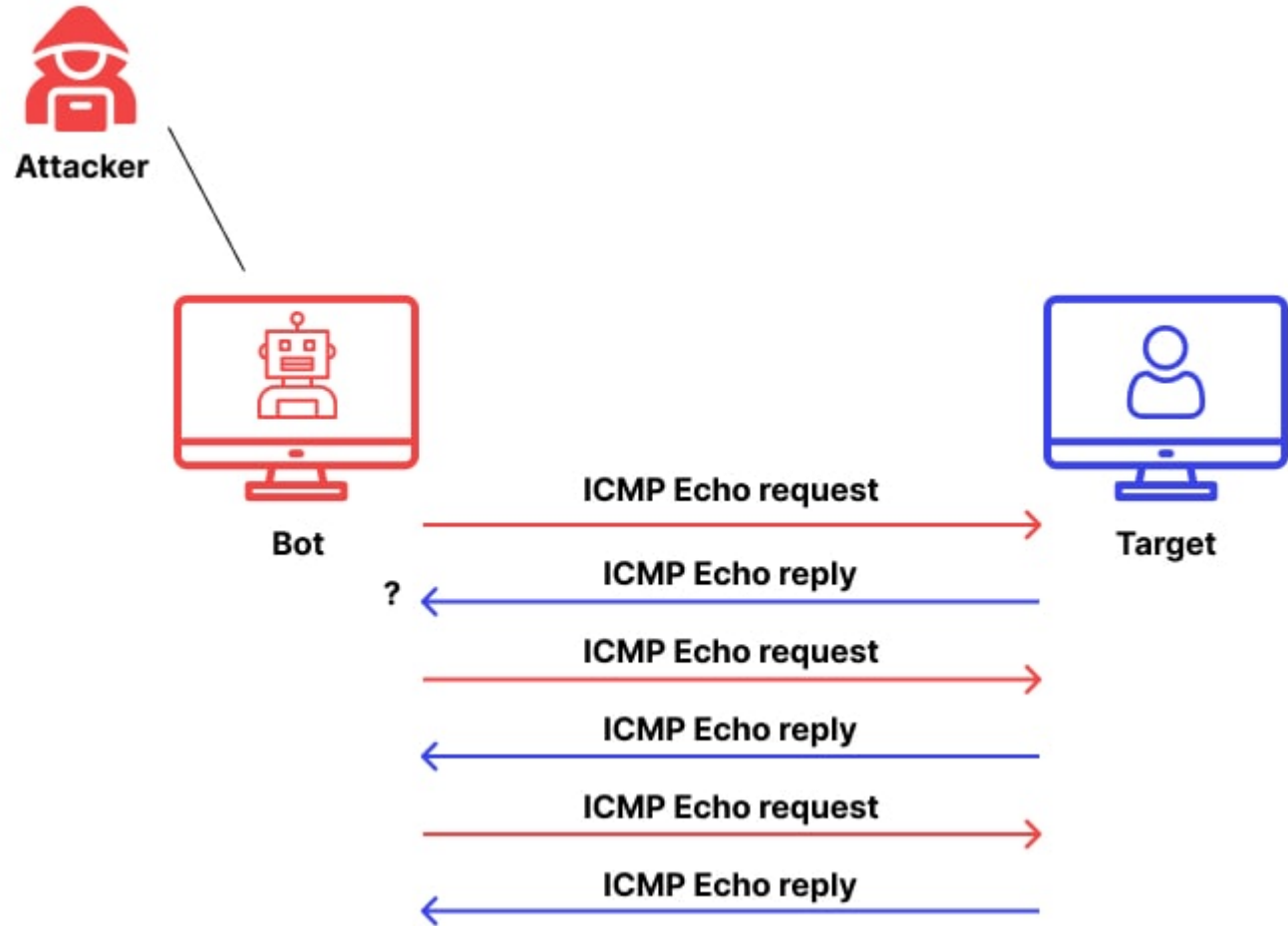
a. User datagram protocol (UDP) flood

- Cuộc tấn công UDP flood truy cập đến cổng ngẫu nhiên trên máy chủ mục tiêu và chiếm dụng tất cả các băng thông truy cập đến hệ thống mục tiêu.
- Loại tấn công UDP flood thậm chí không cho phép hệ thống gửi các gói dữ liệu ICMP destination unreachable.
- Loại tấn công này được xếp vào loại tấn công Flood attack từ nhỏ đến trung bình và được đo bằng Mbps và PPS.



b. ICMP flood

- Là một trong những kỹ thuật flooding lâu đời nhất.
- Tấn công ICMP flood không dựa vào bất kỳ lỗ hổng mà được thực hiện với các loại thông điệp ICMP, như echo request và echo reply.



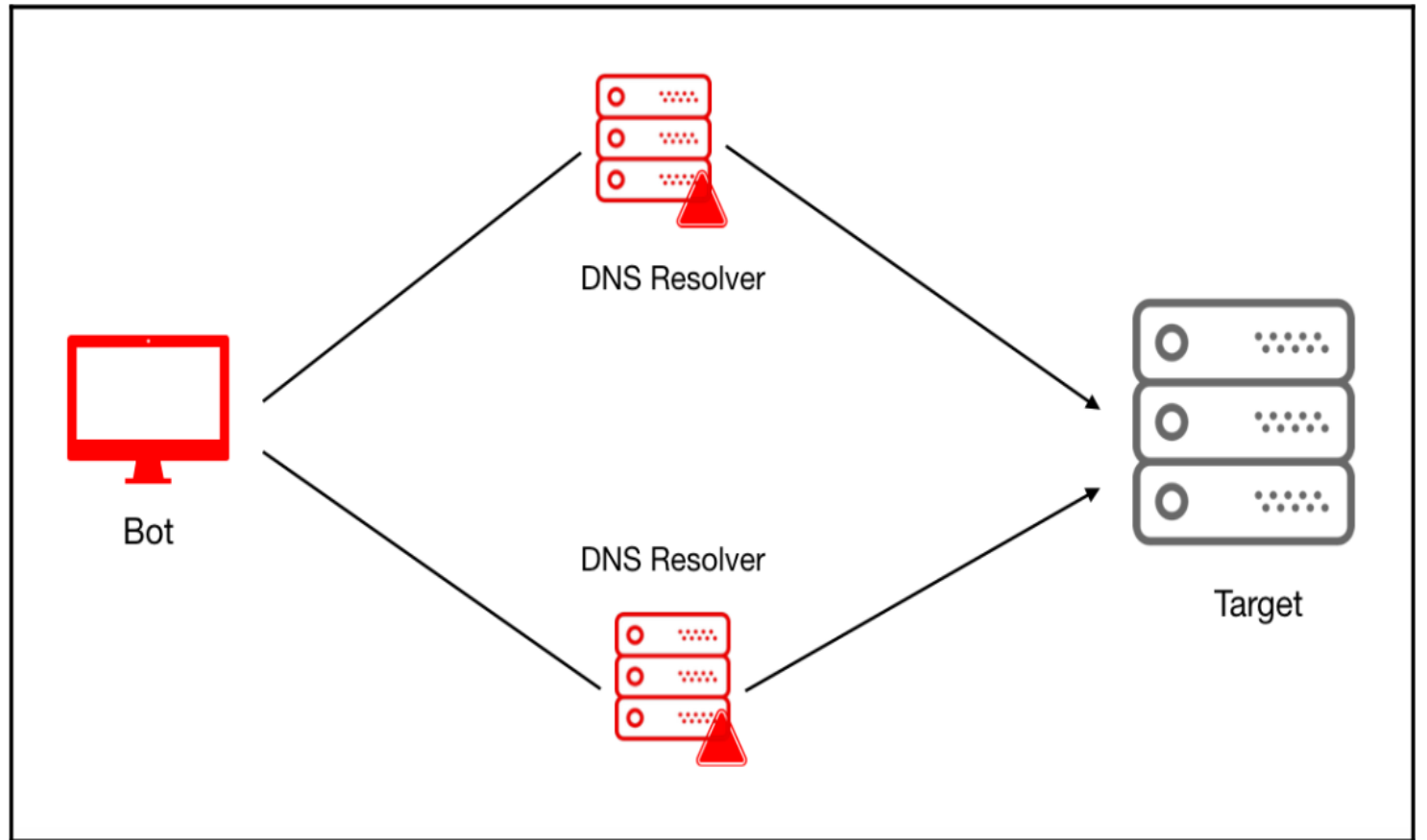
Nguồn: Wallarm

c. Internet Group Management Protocol (IGMP) flood

- IGMP là một giao thức multicast, không kết nối.
- Tấn công IGMP flood không dựa trên lỗ hổng bảo mật mà gửi một lượng lớn các báo cáo thông điệp IGMP đến mạng hoặc bộ định tuyến.

d. Tấn công khuếch đại

- Tấn công khuếch đại dựa trên sự xâm nhập vào router và buộc router gửi thông điệp quảng bá multicast bằng cách giả mạo địa chỉ nguồn.
- Với tấn công khuếch đại DNS, kẻ tấn công có thể xâm nhập một máy chủ DNS để đưa thông tin DNS giả mạo vào hệ thống DNS.



2.2. Các cuộc tấn công tài nguyên máy chủ

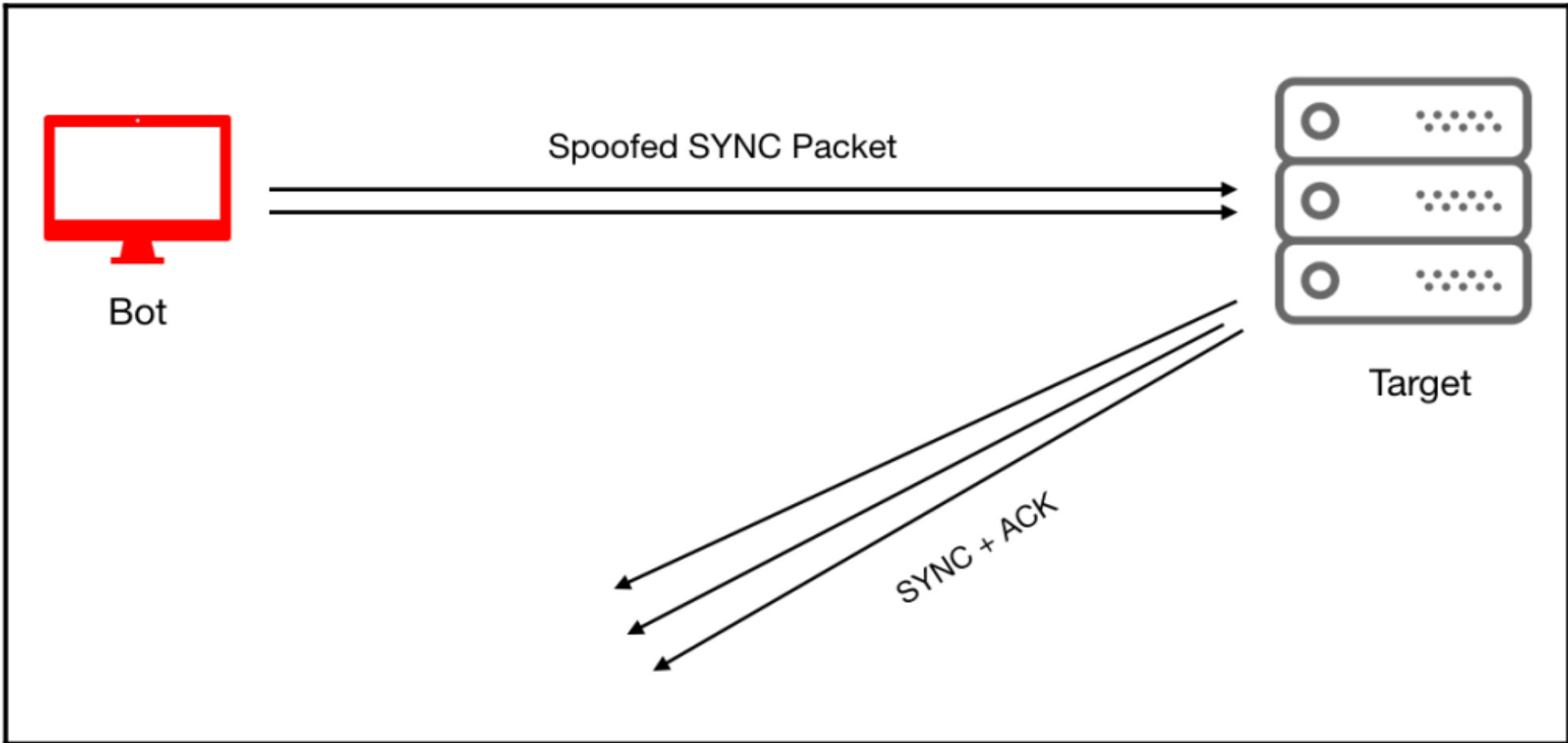
- Các cuộc tấn công tài nguyên máy chủ gây ra sự chiếm dụng cho lưu lượng truy cập hợp lệ.
- Trong loại tấn công này, tin tặc xác định các lỗ hổng của máy chủ mục tiêu và biến phần mềm độc hại thành vũ khí để khai thác các lỗ hổng.

a. TCP SYN Flood

Cuộc tấn công này làm cho việc sử dụng cơ chế bắt tay 3 bước TCP tốn phần lớn tài nguyên máy chủ với các thông điệp đồng bộ TCP:

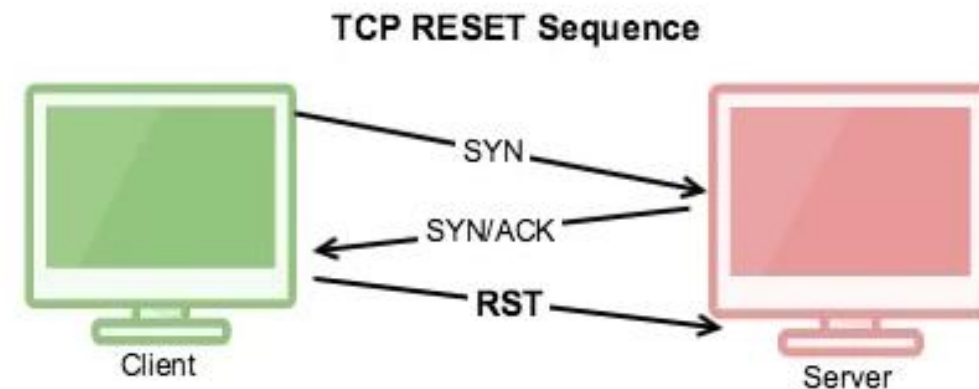
- Hệ thống tấn công gửi một loạt các yêu cầu TCP với cờ TCP thiết lập SYN.
- Để quản lý mỗi yêu cầu này, máy chủ đã mở và phân bổ một số tài nguyên CPU và vùng đệm để chuẩn bị truyền thông.
- Sau đó, máy chủ sẽ gửi một thông điệp TCP với một cờ thiết lập SYN-ACK, và đợi các máy khách báo nhận bằng thông điệp TCP với cờ ACK.
- Hệ thống tấn công nhận được thông tin đó nhưng không bao giờ hồi đáp, và máy chủ phải duy trì các cổng mở và tài nguyên để phân bổ cho cùng một máy khách.
- Tin tặc có thể tiếp tục tạo thêm yêu cầu đến máy chủ để làm máy chủ quá tải tài nguyên và không thể đáp ứng yêu cầu từ những người dùng hợp lệ khác.

a. TCP SYN Flood



b. Tấn công TCP Reset (RST)

- Trong TCP/IP, cờ Reset (RST) được sử dụng để thông báo cho máy chủ nhằm thiết lập lại kết nối TCP đang diễn ra.
- Trong một cuộc tấn công TCP RST, tin tặc chặn kết nối TCP đang hoạt động giữa máy khách và máy chủ bằng cách thử một chuỗi số ngẫu nhiên. Sau khi xác định thành công chuỗi số, kẻ tấn công sẽ giả mạo thông báo TCP RST đến địa chỉ IP nguồn của máy khách.
- Các bot được sử dụng để tấn công và xác định số thứ tự hoạt động.



Nguồn: packtpub

c. Tấn công SSL

- SSL thực thi với TCP/IP và chỉ gửi thông điệp SSL hello khi bắt tay ba bước TCP được hoàn tất.
- Các cuộc tấn công DDoS dựa trên SSL có thể nhắm mục tiêu cơ chế bắt tay SSL, gửi dữ liệu rác ngẫu nhiên đến máy chủ SSL hoặc khai thác một số cơ chế khóa mã hóa SSL liên quan đến các chức năng nhất định.

d. Tấn công HTTP được mã hóa

- Với việc sử dụng ngày càng nhiều các ứng dụng web được mã hóa SSL / TLS, tin tặc cũng đang hướng đến các cuộc tấn công dựa trên HTTP được mã hóa.
- Hầu hết các tổ chức không có giải pháp bảo mật để có thể kiểm tra lưu lượng truy cập SSL nhằm bảo vệ hệ thống hiệu quả chống lại các lưu lượng truy cập độc hại.
- Những kẻ tấn công sử dụng điểm yếu này và sử dụng thêm nhiều tính năng mới để xâm nhập mạng thông qua HTTP được mã hóa.

2.3. Các cuộc tấn công tài nguyên ứng dụng

- Tin tặc đang chuyển từ các phương pháp truyền thống sang các cuộc tấn công dựa trên ứng dụng với HTTPS, DNS, FTP, SMTP và VoIP.
- Các ứng dụng thường được xây dựng với một số thành phần độc lập và có thể tiềm ẩn nhiều lỗi chưa được phát hiện.
- Một số cuộc tấn công được sử dụng rộng rãi hiện nay như: DNS flooding, tấn công DoS dựa trên biểu thức cú pháp, tấn công xung đột băm DDoS...

a. DNS flooding

- Tin tặc dễ dàng phát động tấn công DNS flood và hệ thống bảo mật cũng khó phát hiện.
- Trong loại tấn công này, máy chủ DNS có thể bị quá tải với một số lượng lớn các yêu cầu DNS, làm cho máy chủ nạn nhân không thể xử lý các yêu cầu hợp lệ.
- Kỹ thuật này đã được sử dụng trong cuộc tấn công Mirai gần đây vào mạng Dyn khiến người dùng không thể truy cập YouTube, Twitter, Netflix và một số ứng dụng khác.

b. Tấn công DoS dựa trên biểu thức cú pháp

- Tin tặc sử dụng phương pháp thấp và chậm để tấn công máy chủ nạn nhân bằng cách tận dụng lỗ hổng trong các tập tin thư viện được triển khai trong máy chủ.
- Khi máy khách gửi yêu cầu với các biểu thức cú pháp, một máy chủ đã tiêu tốn một số lượng lớn các nguồn lực để xử lý các biểu thức cú pháp.
- Kẻ tấn công sử dụng kiểu tấn công này để khai thác các máy chủ và thường xuyên gửi biểu thức theo định kỳ mà các hệ thống an ninh không phát hiện được.

c. Tấn công xung đột băm DoS (Hash collision DoS)

- Với loại tấn công này, kẻ tấn công dành nhiều thời gian để xác định các lỗ hổng trong framework ứng dụng web.
- Bảng băm được sử dụng để lập chỉ mục phiên POST trong hầu hết các máy chủ ứng dụng.
- Máy chủ đã quản lý xung đột băm khi giá trị băm tương ứng được trả lại.
- Giải pháp xung đột tiêu tốn rất nhiều tài nguyên xử lý như những kẻ tấn công duy trì việc gửi thông điệp POST với rất nhiều tham số.
- Tin tặc thiết lập các tham số để gây ra xung đột băm ở máy chủ và làm cho máy chủ bận rộn để xử lý xung đột.

3. Thách thức với các giải pháp DDoS hiện nay

- Nhiều tổ chức bị tấn công DDoS nhưng không biết liệu họ có bị tấn công hay không.
- Vào ngày 28 tháng 2 năm 2018, GitHub, trang web lưu trữ mã nguồn mở, đã bị tấn công DDoS lớn nhất từ trước đến nay, được ghi nhận ở mức 1,35 TBps.
- Các cuộc tấn công DDoS luôn nằm trong danh mục mối đe dọa mạng; tuy nhiên, việc triển khai bất kỳ cơ chế ngăn chặn rất khó khăn vì chúng ta không thể kiểm soát các mối đe dọa mạng từ bên ngoài.
- Việc các ứng dụng web tiếp nhận các yêu cầu của người dùng tập trung tại các server Frontend sẽ là một rủi ro nhất định cho các tổ chức khi bị tin tặc nhắm đến khi tấn công DDoS.

4. Giải pháp Blockchain để chuyển đổi các nền tảng bảo vệ DDoS hiện có

- Theo định nghĩa, Blockchain là một mạng phân tán cho phép các bên độc lập giao tiếp mà không có bất kỳ sự tham gia của bên thứ ba nào.
- Để bảo vệ mạng khỏi các cuộc tấn công DDoS, các tổ chức có thể sử dụng nhiều nút máy chủ cung cấp khả năng phục hồi cao và loại bỏ một số máy chủ tiếp nhận tập trung nhằm giảm thiểu vấn đề điểm thất bại duy nhất (single point of failure).
- Có hai lợi thế chính để sử dụng Blockchain, đó là:
 - Công nghệ Blockchain có thể được sử dụng để triển khai một sổ cái phân tán để lưu trữ IP Blacklist.
 - Công nghệ Blockchain loại bỏ nguy cơ điểm thất bại duy nhất.

5. Kết luận

- Trong chương này, chúng ta đã tìm hiểu về các cuộc tấn công DDoS và cách chúng hoạt động.
- Chúng ta đã hiểu những thách thức với các giải pháp DDoS hiện nay và cách sử dụng Blockchain để giúp chúng ta có các giải pháp tốt hơn để bảo vệ hệ thống mạng của tổ chức một cách hiệu quả khỏi các vụ tấn công DDoS.

